# Penetration Test Report_BSides Vancouver 2018

## 1. Executive Summary

Il presente documento dettaglia le attività di Penetration Testing eseguite sulla macchina virtuale "BSides Vancouver 2018". L'obiettivo del test era identificare vulnerabilità nel sistema e ottenere l'accesso di massimo livello (Root). L'attacco ha avuto successo sfruttando una catena di vulnerabilità: un'errata configurazione dei servizi web (password deboli e riutilizzo delle stesse) che ha permesso l'accesso iniziale, seguita dallo sfruttamento di un *Cron Job* (operazione pianificata) con permessi insicuri, che ha portato alla compromissione totale del sistema.

---

## 2. Metodologia e Catena d'Attacco (Kill Chain)

### Fase 1: Ricognizione ed Enumerazione (Reconnaissance)

L'analisi è iniziata con una scansione completa delle porte TCP, che ha rivelato l'esposizione di tre servizi principali: FTP (21), SSH (22) e HTTP (80). L'accesso anonimo al servizio FTP ha permesso il recupero di un file di backup sensibile (`users.txt.bk`), fornendo una lista di nomi utente validi per il sistema: `abatchy`, `john`, `mai`, `anne`, `doomguy`.

**Comandi utilizzati:**

- `nmap -p- --min-rate 1000 -sV -sC 10.0.2.6`
- `ftp 10.0.2.6` (Login: *anonymous*)
- `get users.txt.bk`

### Fase 2: Accesso Iniziale (Initial Foothold)

L'analisi del servizio HTTP ha rivelato un'installazione obsoleta di WordPress (versione 4.5) nella directory `/backup_wordpress`. Avendo a disposizione una lista di utenti validi recuperata dall'FTP, si è proceduto con un attacco mirato alle credenziali.

**La scoperta della password "enigma":** Invece di procedere con un attacco di forza bruta estensivo e rumoroso, è stato eseguito un *Targeted Password Spraying*. Utilizzando la top-1000 delle password più comuni derivate da data breach pubblici (estratte dal dizionario `rockyou.txt`), è stato automatizzato un attacco contro l'endpoint XML-RPC di WordPress per i soli utenti identificati. L'attacco ha rivelato in pochi secondi un *Password Reuse* critico: l'utente `john` utilizzava la password debole `enigma`.

**Comandi utilizzati:**

- `wpscan --url http://10.0.2.6/backup_wordpress -U john,doomguy,admin -P /usr/share/wordlists/rockyou.txt` *(Interrotto non appena individuato l'hit positivo)*

## Fase 3: Esecuzione di Codice Remoto (Weaponization)

Ottenuto l'accesso al pannello di amministrazione di WordPress (`wp-admin`) con l'account di `john`, si è sfruttata la funzionalità di modifica dei temi ("Appearance -> Editor"). Il codice legittimo del file `404.php` del tema *Twenty Sixteen* è stato sostituito con un payload PHP per generare una *Reverse Shell*. Visitando la pagina inesistente, il server ha stabilito una connessione con la macchina attaccante, fornendo una shell interattiva come utente `www-data`.

**Comandi utilizzati:**

- `nc -lvnp 4444` (Sulla macchina attaccante)
- `python -c 'import pty; pty.spawn("/bin/bash")'` (Per stabilizzare la shell ottenuta)

## Fase 4: Scalata dei Privilegi (Privilege Escalation)

L'enumerazione locale del sistema ha rivelato la presenza del file `/var/www/wordpress-4.5.zip` di proprietà dell'utente `abatchy`. L'analisi delle operazioni pianificate di sistema (`/etc/crontab`) ha evidenziato una grave *misconfiguration*: uno script di pulizia (`/usr/local/bin/cleanup`) veniva eseguito ogni minuto con i privilegi dell'utente `root`.

Verificando i permessi di tale script (`-rwxrwxrwx`), è emerso che qualsiasi utente del sistema (incluso `www-data`) poteva modificarne il contenuto. Lo script originale è stato sovrascritto con un comando progettato per assegnare il bit SUID alla shell di sistema `/bin/bash`. Attendendo l'esecuzione pianificata, la shell ha acquisito i permessi necessari per garantire l'accesso Root persistente.

**Comandi utilizzati:**

- `cat /etc/crontab`
- `ls -la /usr/local/bin/cleanup`
- `echo '#!/bin/sh' > /usr/local/bin/cleanup`
- `echo 'chmod +s /bin/bash' >> /usr/local/bin/cleanup`
- `ls -la /bin/bash` (In attesa della modifica dei permessi in `-rwsr-sr-x`)
- `/bin/bash -p` (Ottenimento privilegi di Root)

---

# 3. Strade Alternative (What If - "Did you find them all?")

L'autore della macchina virtuale suggerisce la presenza di vettori d'attacco multipli. Durante l'analisi, sono state identificate teoricamente le seguenti strade alternative per la compromissione:

1. **Privilege Escalation tramite Kernel Exploit (Dirty COW):** Il sistema operativo target è basato su Ubuntu 12.04 (Precise Pangolin) con Kernel `3.11.0-15-generic`. Questa specifica versione è notoriamente vulnerabile a **CVE-2016-5195 (Dirty COW)**. Se il vettore del Cron Job non fosse stato disponibile o fosse stato adeguatamente protetto, un attaccante avrebbe potuto compilare localmente un exploit in C per sfruttare la *race condition* del sottosistema di memoria del kernel, ottenendo i privilegi di root in pochi istanti.
2. **Sfruttamento diretto di WordPress (CVE Pubblici):** L'installazione di WordPress alla versione 4.5 è gravemente obsoleta. Un'analisi più approfondita dei plugin (sebbene apparentemente non rilevati in modo passivo) o di vulnerabilità *Core* di quella specifica release avrebbe potuto permettere una *Remote Code Execution* diretta, senza la necessità di recuperare la password utente tramite dizionario.
3. **Abuso delle Credenziali del Database:** Durante la fase di Post-Exploitation, è stata estratta la password del database ( `thiscannotbeit` ). Sebbene il tentativo di *Lateral Movement* verso l'account di sistema `john` sia fallito, in uno scenario reale queste credenziali avrebbero potuto essere utilizzate per accedere direttamente al database MySQL, estrarre gli hash delle password di tutti gli altri utenti WordPress (es. `abatchy` ) e forzarli offline (Password Cracking) per ottenere nuovi vettori d'accesso.

```
bash-4.2# cat flag.txt
cat flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@abatchy17

bash-4.2#
```